

INTERNSHIP PROJECT REPORT

Web Application Security Assessment & Improvement

Task 1: Security Assessment — Findings

Objective

The objective of this task was to identify security vulnerabilities in a User Management Web Application using a combination of manual testing techniques and automated scanning tools. The findings documented below reflect the security posture of the application prior to any remediation.

Vulnerabilities Identified

The following six vulnerabilities were identified during the security assessment. Each finding includes a description and an assessment of its potential impact.

1	Brute Force Vulnerability	Severity: High
Impact	The application permits unlimited login attempts without restriction, making it susceptible to brute-force attacks where an attacker can systematically try different password combinations until access is gained.	
2	Missing Content Security Policy (CSP)	Severity: High
Impact	The absence of a Content Security Policy header significantly increases the risk of Cross-Site Scripting (XSS) attacks, allowing attackers to inject and execute malicious scripts in users' browsers.	
3	Missing X-Frame-Options Header	Severity: Medium

Impact	Without this header the application can be embedded within iframes on malicious websites, exposing users to clickjacking attacks where they are tricked into performing unintended actions.
--------	---

4	Missing X-Content-Type-Options Header	Severity: Medium
Impact	The lack of content type protection may permit MIME-type sniffing, enabling browsers to misinterpret file types and potentially execute malicious content served by an attacker.	

5	Information Disclosure (X-Powered-By Header)	Severity: Medium
Impact	The server reveals technology stack information through the X-Powered-By response header, enabling attackers to identify the framework and target known vulnerabilities specific to that technology.	

6	Cross-Origin Resource Sharing (CORS) Misconfiguration	Severity: Medium
Impact	Improper CORS configuration may allow unauthorised domains to make cross-origin requests to the application's API, potentially exposing sensitive user data to malicious third parties.	

Areas of Improvement

Based on the vulnerabilities identified, the following remediation measures are recommended to improve the application's security posture:

- Implement login attempt limits and account lockout mechanisms to prevent brute-force attacks
- Add missing security headers: Content Security Policy (CSP), X-Frame-Options, and X-Content-Type-Options
- Disable the X-Powered-By header to prevent technology stack disclosure
- Configure strict Cross-Origin Resource Sharing (CORS) policies
- Improve authentication controls, including session timeout and Multi-Factor Authentication (MFA)
- Establish a process for regular security testing and automated vulnerability scanning.

Summary

The security assessment identified multiple security misconfigurations and a critical lack of brute-force protection within the User Management Web Application. While the application includes basic input validation and authentication mechanisms, the findings indicate that significant additional security measures are required to achieve an acceptable level of protection.

Key Assessment Findings

- 6 vulnerabilities identified — 2 High severity, 4 Medium severity.
- No rate limiting or account lockout exists, leaving authentication highly exposed.
- Multiple HTTP security headers are absent, increasing the attack surface.
- CORS misconfiguration may result in unauthorised cross-origin data access.
- Immediate remediation of High severity findings is strongly recommended.

This report concludes the Task 1 security assessment findings for the internship project.